

Threat hunt - Executive Summary

Public facing shared services Brute-Force Compromise | Cyber Range

Date: 30 June 2026	Analyst: Giorgi Chkonia	Severity: High	Status: Open/Unremediated
---------------------------	--------------------------------	-----------------------	----------------------------------

Summary

A proactive threat hunt confirmed that two internet-exposed shared services Linux machines were successfully Brute Forced from external IP addresses. First machine shows successful logon after more than 200 tries and second machine shows that an attacker escalated to root and installed SMB(samba) and FTP services to stage data exfiltration. No data was exfiltrated and no lateral movement occurred. Investigation found that no security control stopped the attacker, the host remains internet-exposed, compromised credentials remain valid, and attacker installed services are still valid. The attacker stopped the activity after staging, immediate action is required

Key Findings

VM	107.175.227.45	Brute force succeeded (224 failed logins → root) across two waves. All sessions were non-interactive (network-type); no hands-on post-exploitation observed in process telemetry.
VM	103.165.61.114	External interactive login as labuser → privilege escalation to root via sudo → installed & configured SMB (Samba) and FTP (vsftpd) and tested the FTP channel locally. No external use of the channel and no lateral movement. No containment occurred, host still exposed, credentials still valid, services still active.

Business Impact

Root-level credentials on an infrastructure host must be considered compromised, and the host remains reachable from the internet with the attacker controlled exfiltration channel in place. While no lateral movement has occurred to date, the absence of containment means impact is not contained; the actor can return at any time. Risk is assessed as **HIGH and active** until remediation is completed.

Recommended Actions (Priority Order)

P1 — Contain & cut access (now): Isolate and revoke sessions/SSH keys; block 103.165.61.114 and 107.175.227.45.

P1 — Remove exposure: reassign to a private IP / restrict the NSG so only management ranges reach SSH; close ports 21, 445, 139 to the internet.

P2 — Eradicate: remove attacker-installed vsftpd/samba and modified configs; hunt for persistence (cron, authorized_keys, new users); rebuild from a known-good image.

P3 — Harden: enforce account lockout/fail2ban, disable SSH password auth, require MFA/key-based auth, restrict sudo, and operationalize the brute-force detection.

MITRE ATT&CK: T1110 Brute Force • T1078 Valid Accounts • T1133 External Remote Services • T1548.003 Sudo Abuse • T1543 Create/Modify System Process • T1048 Exfiltration Over Alternative Protocol (staged, not executed) Prepared for internal review.